



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



ServiceNow Hosted Instance API Security Incident

Threat Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | ServiceNow Hosted Instance API Security Incident - Threat Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement and Scope
3. Source Review and Confidence
4. Incident Overview
5. Timeline
6. Technical Analysis
7. Threat Activity Assessment
8. Infrastructure and Indicators
9. Victimology and Targeting
10. Detection Engineering
11. Threat Hunting Guidance
12. Risk Assessment
13. Recommended Actions
14. Bottom-Line Assessment
15. References

ServiceNow Hosted Instance API Security Incident — Threat Intelligence Report

Classification: TLP:CLEAR Published: 2026-06-10 Version: 1.0 Author: Lost Boys Cyber Report Type: Threat Intelligence Report Severity: High

1. Executive Summary

Between 2-3 June 2026, attackers exploited a ServiceNow-hosted API access control failure to query data from a subset of customer instances before the vendor pushed a hosted fix on 5 June. Public reporting and multiple secondary sources consistently indicate the exposure was tied to an endpoint associated with `/api/now/related_list_edit/create` and a configuration state that allowed unauthenticated access. The most material enterprise risk is not only the direct exposure of tickets, employee records, workflow data, and security cases, but the secondary exposure of credentials, API tokens, integration secrets, and internal process knowledge commonly stored in ServiceNow records.

Expected impact is HIGH for directly affected tenants and MODERATE for the broader ServiceNow customer base. For affected organisations, likely consequences include regulatory notification pressure, third-party risk escalation, targeted follow-on intrusion using harvested secrets, and trust degradation around SaaS control boundaries. For customers not individually notified by ServiceNow, immediate platform compromise risk appears reduced after the 5 June hosted remediation, but log review, secret rotation for sensitive records, and validation of legacy/custom API exposure remain warranted.

2. Intelligence Requirement and Scope

This report assesses the June 2026 ServiceNow hosted-instance security incident, with emphasis on what is vendor-confirmed, what is community-reported, the likely data at risk, the detection implications for enterprise defenders, and the expected downstream business impact for affected organisations.

This report does not assume compromise of the ServiceNow corporate environment itself. The available evidence points to unauthorised access against customer instances via a public-facing API control failure.

3. Source Review and Confidence

Source ID	Source	Assessment
SRC-001	ServiceNow support bulletin KB3067321, quoted by multiple outlets	Highest-confidence source for remediation date, affected scope, customer notification model, and vendor wording.
SRC-002	BleepingComputer reporting mirrored at <code>note.f5.pm</code>	Strong secondary source summarising the hidden vendor bulletin and operational implications.
SRC-003	The CyberSec Guru technical write-up	Useful for probable root cause and hunt indicators; several claims remain single-sourced.
SRC-004	Triskele Labs advisory	Strong defender-focused synthesis that clearly distinguishes confirmed from unconfirmed details.
SRC-005	Anavem and other tertiary summaries	Supportive corroboration for business-impact framing only.

Overall confidence is HIGH for incident existence, patch timing, and confirmed successful queries against a subset of customers; MEDIUM for exact technical root cause; and LOW-TO-MEDIUM for some reported infrastructure indicators and pre-disclosure timeline details.

4. Incident Overview

On 5 June 2026, ServiceNow applied a hosted security update to customer instances after identifying a security issue that could allow an unauthenticated user, in certain circumstances, to gain greater access to ServiceNow instances than intended. According to the quoted vendor bulletin, ServiceNow also detected anomalous activity related to the issue and observed evidence of successful queries of instance tables for a subset of customers.

The public reporting available at the time of writing consistently describes this as a hosted-platform incident rather than a self-managed patching exercise. ServiceNow reportedly notified affected customers directly via support cases and stated that customers not contacted were not believed to be affected.

5. Timeline

Date	Event	Confidence
2026-04-07	Single-source claim that ServiceNow had internally documented the issue in a problem record.	Low-Medium
2026-06-02 to 2026-06-03	Observed anomalous activity and probable exploitation window across affected tenants.	High
2026-06-05	ServiceNow applies a hosted security update restricting the affected endpoint to authenticated users.	High
2026-06-09	Customers receive support-case notifications; broader public reporting begins to surface.	High
2026-06-10	Third-party analyses expand hunting guidance, suspected endpoint details, and business-impact framing.	High

6.1 Assessed Root Cause

Public reporting strongly suggests the incident involved a Scripted REST Resource associated with ``/api/now/related_list_edit/create``. Multiple sources state the endpoint was configured such that authentication was not required, and that the 5 June update changed the endpoint configuration to restrict access to authenticated users only.

Important caveat: ServiceNow has not publicly confirmed the exact endpoint path or publicly released a detailed root-cause advisory at the time of this report. Accordingly, the specific implementation detail should be treated as a high-value working hypothesis rather than a public vendor-confirmed fact.

6.2 Affected Scope

The quoted vendor language indicates the incident primarily affected:

- Customers on the Australia platform release.
- Customers on releases prior to Australia that made certain configuration changes.

This scope limitation matters because it reduces the likelihood of indiscriminate exposure across all tenants, but it does not materially reduce the seriousness for impacted organisations. A smaller affected population can still produce severe downstream compromise where ServiceNow is used as a store of privileged operational information.

6.3 Access Pattern and Logging Implications

Community and third-party reporting indicates:

- Requests may have targeted the endpoint roughly five times per tenant in several affected environments.

- Unauthenticated activity may appear in logs under the `Guest` context because no valid session or user principal existed.
- Many customers may lack full request/response visibility because REST message logging was not enabled before the incident.

This creates a common SaaS-forensics problem: defenders may be able to prove that suspicious requests hit the endpoint, while remaining unable to reconstruct exactly which records or fields were returned.

6.4 Likely Data at Risk

Depending on instance usage, the following categories should be treated as plausibly exposed:

- ITSM records: incidents, problems, change tickets, CMDB records, and service requests.
- Security operations data: detections, investigations, vulnerability workflows, and response notes.
- Human resources or employee-service data where the platform is used outside pure ITSM.
- Internal documentation, workflow notes, architectural references, and attachments.
- Embedded secrets: API keys, temporary credentials, admin screenshots, troubleshooting artefacts, MFA recovery material, VPN details, or cloud integration strings.

6.5 What is Confirmed vs. Assessed

Confirmed at high confidence:

- Hosted security update applied on 5 June 2026.
- Vendor observed anomalous activity.
- Successful queries of instance tables for a subset of customers.
- Affected customers were notified directly.
- CVE publication remained under evaluation as of reporting.

Assessed but not fully vendor-confirmed in public:

- Endpoint path `/api/now/related\_list\_edit/create`.
- `requires\_authentication=false` as the precise root cause.
- `Guest` user attribution pattern in logs.
- Suspicious source IPs 51.159.98.241 and 86.245.155.105.
- Internal ServiceNow awareness date of 7 April 2026.

7. Threat Activity Assessment

No public attribution exists tying the exploitation to a named threat actor. At present, the activity is best understood as opportunistic exploitation of a high-value SaaS misconfiguration or access-control failure.

However, the target profile materially elevates the threat. ServiceNow instances often function as an enterprise operational memory store. An actor who can enumerate and query those records may gain:

- Knowledge of internal architecture and change windows.
- Credentials and tokens left in tickets or attachments.
- Help-desk process insight useful for social engineering.
- Security-operations artefacts that reveal monitoring gaps or active investigations.

That means even limited data access can materially increase the success probability of later phishing, identity abuse, cloud exploitation, or vendor impersonation operations.

8. Infrastructure and Indicators

Type	Value	Confidence	Notes
Source IP	51.159.98.241	Medium	Most consistently cited suspicious IP in community and third-party reporting.
Source IP	86.245.155.105	Low	Single-source possible

			secondary IP; retain as hunt lead only.
URI Path	/api/now/related_list_edit/create	Medium	Community-reported vulnerable endpoint.
User Context	Guest	Medium	Reported logging artefact for unauthenticated requests.
Time Window	2026-06-02 through 2026-06-03 UTC	High	Likely primary exploitation window before hosted fix.

9. Victimology and Targeting

Potentially exposed organisations include enterprises that use ServiceNow to centralise ITSM, SecOps, HR, asset management, and workflow automation. Particularly sensitive verticals include:

- Healthcare, where tickets may include protected health information and privileged workflows.
- Financial services, where operational records may expose change management and privileged integration detail.
- Government and defence, where case records can reveal mission support data, asset inventories, and security workflows.
- Managed service providers and SaaS operators, where ServiceNow records may contain downstream customer details and administrative procedures.

10.1 Detection Priorities

Priority	Signal	Why it matters
1	Requests to `/api/now/related_list_edit/create` during 2-3 June 2026	Highest-confidence hunt lead tied to public reporting.
2	Requests from 51.159.98.241 or 86.245.155.105	Useful infrastructure pivot, though not definitive alone.
3	`Guest`-context access to related-list edit operations	May identify unauthenticated activity hidden as non-user actions.
4	Abrupt spikes in table-query volume or unusual row-access patterns	Can reveal broader enumeration outside the primary IOC set.
5	Post-incident use of secrets stored in tickets or attachments	Detects likely follow-on exploitation rather than the initial exposure alone.

10.2 Example Microsoft Sentinel / KQL Hunt

```
let suspiciousIPs = dynamic(["51.159.98.241", "86.245.155.105"]);
let suspiciousPath = "/api/now/related_list_edit/create";
ServiceNowLogs
| where TimeGenerated between (datetime(2026-06-02) .. datetime(2026-06-06))
| where Url has suspiciousPath or RequestUri has suspiciousPath or RawData has suspiciousPath
| extend SourceIP = coalesce(ClientIP, SrcIpAddr, SourceIP, RemoteIP)
| extend UserContext = coalesce(User, UserName, Account, tostring(parse_json(AdditionalFields).user))
| summarize Requests=count(), DistinctIPs=dcount(SourceIP), FirstSeen=min(TimeGenerated),
LastSeen=max(TimeGenerated) by Tenant=coalesce(Instance, TenantId, Hostname), SourceIP, UserContext,
tostring(HttpMethod), tostring(HttpStatus)
| order by Requests desc
```

10.3 Example Splunk Hunt

```
index=servicenow (uri_path="/api/now/related_list_edit/create" OR
request_uri="/api/now/related_list_edit/create" OR _raw="/api/now/related_list_edit/create")
```

```

| eval source_ip=coalesce(src_ip, client_ip, remote_addr, ip)
| eval user_context=coalesce(user, user_name, account, principal, "unknown")
| search earliest="06/02/2026:00:00:00" latest="06/06/2026:23:59:59"
| stats count as requests min(_time) as first_seen max(_time) as last_seen values(method) as methods
  values(status) as statuses by host source_ip user_context
| convert ctime(first_seen) ctime(last_seen)
| sort - requests

```

10.4 Example Sigma Analytic Logic

```

title: ServiceNow Related List Edit Endpoint Queried from Untrusted Source
id: 9a4694de-3e5f-42d4-a75a-182552620001
status: experimental
description: Detects requests to the community-reported ServiceNow endpoint associated with the June
2026 hosted-instance security incident.
author: Lost Boys Cyber
logsource:
  category: webserver
  product: servicenow

detection:
  selection_path:
    cs-uri-stem|contains: '/api/now/related_list_edit/create'
  selection_ip:
    c-ip:
      - '51.159.98.241'
      - '86.245.155.105'
  condition: selection_path or (selection_path and selection_ip)
fields:
  - c-ip
  - cs-uri-stem
  - cs-method
  - sc-status
  - cs-username
falsepositives:
  - Legitimate internal testing of the same endpoint
level: high

```

11. Threat Hunting Guidance

1. Pull all transaction, node, API gateway, and reverse-proxy logs covering 1-6 June 2026.
2. Hunt for the endpoint path and suspicious IPs across ServiceNow-native logs and any external WAF/CDN logs.
3. Review all records accessed in the relevant window for embedded secrets, architecture notes, screenshots, attachments, and privileged change tickets.
4. Cross-check subsequent authentication events in identity providers, PAM tools, VPN concentrators, cloud consoles, and developer platforms for accounts or secrets that appeared in those records.
5. Review outbound communications or phishing attempts themed around help-desk, incident-response, or change-management topics in the days following the incident.

12. Risk Assessment

Dimension	Assessment
Confidentiality	High for affected tenants because records may contain sensitive business data and credentials.
Integrity	Medium because the clearest public evidence points to successful query activity, but some reporting suggests write attempts may also have occurred.
Availability	Low direct impact from the incident itself; main risk is

	downstream disruption if exposed secrets are abused.
Regulatory / Compliance	High for affected organisations in regulated sectors due to possible exposure of personal, security, or support-case data.
Third-Party / Vendor Risk	High because the incident occurred inside a trusted SaaS workflow platform and may trigger review of shared-responsibility assumptions.

13.1 Immediate (0-24 hours)

- Confirm whether your organisation received a ServiceNow support case tied to this incident.
- Preserve all relevant ServiceNow logs, WAF logs, and SIEM evidence from 1-6 June 2026.
- Identify records likely to contain secrets and begin risk-ranked secret rotation.
- Notify legal/privacy/vendor-risk teams if suspicious access is confirmed.

13.2 Near-Term (1-7 days)

- Audit all Scripted REST Resources, especially legacy or rarely reviewed endpoints, for both authentication and ACL enforcement.
- Review attachments, tickets, and knowledge entries for plaintext credentials or sensitive troubleshooting artefacts.
- Validate whether compensating controls such as IP restrictions, WAF rules, API monitoring, and anomaly alerting are in place.
- Reassess vendor-assurance questions around notification timeliness, logging sufficiency, and change-control visibility.

13.3 Strategic (7-30 days)

- Reduce secret sprawl in ticketing and workflow systems by enforcing secure secret-sharing alternatives.
- Establish a SaaS incident response playbook for third-party platforms that hold privileged operational data.
- Build detections around abnormal ServiceNow data access volume, unauthenticated endpoint exposure, and post-ticket credential abuse.
- Treat enterprise workflow platforms as high-value information repositories in threat models, not merely as administrative tooling.

14. Bottom-Line Assessment

The ServiceNow incident should be assessed as a confirmed third-party SaaS security event with potentially outsized downstream consequences. The strongest current evidence supports successful unauthorised data queries against a limited subset of customer instances rather than a universal platform-wide catastrophe. Even so, because ServiceNow often stores the exact operational detail attackers need for privilege escalation and social engineering, affected organisations should treat any confirmed access as a possible precursor to broader compromise.

15. References

6. ServiceNow KB3067321, vendor support bulletin quoted in secondary reporting; customer portal access required.
7. BleepingComputer reporting mirrored at <https://note.f5.pm/go-422046.html>
8. The CyberSec Guru, “ServiceNow API Breach: What Customers Need to Know Now”
9. Triskele Labs, “ServiceNow Security Incident: Unauthenticated API Access Exposing Customer Instance Data”
10. Anavem, “ServiceNow API Flaw Exposes Customer Data in Security Breach”